

Adversary position, what it can produce, and what answers it

position and capability	attack	the control that answers it	B1	P	
P1 on the network path <i>captured request bytes; no private key</i>	A1 replay	jti replay cache and iat skew (stage 2)	0.00	0.00	Assets under protection • account and transaction data of 100 synthetic ADR users • consent scope integrity • the account's own device key • availability of the API
P2 client-storage exfiltration <i>a valid access token; no private key</i>	A2 token theft	cnf.jkt thumbprint comparison (stage 2)	0.00	0.00	
P3 resident on the enrolled device <i>the account's own key; can sign any proof</i>	A3 key abuse A6 volume	call-rate rule only (stage 4)	1.00	1.00	Trusted by assumption • ECDSA and JWT signatures are unforgeable • the IdP is not compromised and its signing key stays secret • controller, policy engine and resource server execute as written • the internal network is not reachable by the adversary
P4 holds the account credentials <i>own device, own key, own genuine token</i>	A4 ATO, new device	per-subject device registry (stage 3)	1.00	0.37	
P5 authenticated as another user <i>own valid session, other users' object ids</i>	A5 BOLA / BFLA	object ownership at the resource server	0.00	0.00	Out of scope • OS or kernel compromise that exfiltrates the device key • attacks on the IdP or on the cryptographic primitives • denial of service
<i>A7 — P4 again, but adaptive: the adversary paces below the rate rule and mimics the victim's self-reported context</i>			1.00	1.00	

Figures are measured attack success rates — the fraction of 30 attempts that returned protected data. Lower is better for the defence.